GRUPO PARROQUIAL NUESTRA SEÑORA DE LOS DESAMPARADOS · MÁLAGA

Auditoría completa de la web, el CMS y el área de hermanos

Seguridad, permisos, lógica de negocio, web pública, rendimiento y salud del proyecto, sobre la rama `main` en el commit `2e5b4a9`.

2	21	34	11
graves	medios	bajos	informativos

68 hallazgos distintos (uno lo encontraron dos revisiones por separado y cuenta una vez). Ninguna ruta privada está abierta por error, las suites de pruebas están prácticamente en verde y los cinco hallazgos altos de la auditoría del 11 de septiembre siguen arreglados.

7 de octubre de 2026 · Seis revisiones en paralelo, en solo lectura: acceso y autorización; subidas, datos personales y configuración; lógica de negocio; web pública, contenido, SEO y accesibilidad; frontend y rendimiento; tipos, pruebas y salud del proyecto. Los hallazgos graves y los de antes del estreno se han comprobado de nuevo contra el código.

1. Resumen

Cómo está el proyecto

COMPROBACIÓN	RESULTADO	DETALLE
Tipos del backend (`npm run comprobar-tipos`)	Pasa	Sin errores.
Tipos del frontend (`npx tsc -b`)	Pasa	Sin errores.
Pruebas del backend (`npm test`)	1 falla	1484 de 1485, ninguna omitida (la base estaba arriba). La que falla depende de lo editado en la base local; en el CI, con base nueva, pasa (SA1).
Pruebas del frontend (`vitest run`)	Pasa	1315 pruebas en 189 ficheros. PortadaAdminPage no dio esta vez sus dos rojos falsos.
Lint de la web (oxlint)	Pasa	0 errores y 34 avisos (SA10).
Prisma	Cuadra	87 migraciones aplicadas, esquema y base sin diferencias, nombres correlativos.
Rutas privadas sin sesión	Cerradas	Las 272 responden 401; las 15 que dan 200 son públicas a propósito.
`npm audit` y secretos	Limpio	0 avisos en los dos proyectos; ningún secreto real en el historial de git.

Por dónde empezar

1. **Doble cobro de un recibo devuelto** (NG1). Si el hermano paga en línea mientras la mesa le cobra en efectivo, paga dos veces y quedan dos ingresos en Contabilidad.
2. **Se pierde lo escrito en el CMS** (FR1). La sesión dura 8 h fijas; si caduca mientras se escribe, al guardar saca al acceso y se pierde el texto.
3. **Pago de pruebas en producción** (DS2). Con la configuración de pruebas la API arranca igual y cualquiera podría marcar pedidos como pagados.
4. **Comprobar DNI desde fuera** (AC1, AC2). Se puede averiguar quién es hermano, un dato de creencias protegido por el RGPD.
5. **La mesa de reparto abre el censo** (AC3). Tesorería y Albacería ven y corrigen el DNI y el contacto de cualquier ficha todo el año.
6. **Documentos privados del alta** (AC6, DS1). Los descarga cualquier rol del CMS, y la foto `.webp` del alta nunca se borra.
7. **Datos de otro hermano en un ordenador compartido** (FR2). Cerrar sesión no limpia la caché de la web.

Los siete son arreglos pequeños y conviene hacerlos antes del estreno. El resto puede ir entrando por orden de gravedad.

Lo que aguanta bien

- **Rutas y sesión:** ninguna ruta privada abierta por orden de declaración; `checkRole` exige la sesión del CMS y el rol se refresca desde la base en cada petición; tokens con tipo, área y corte por área.
- **IDOR:** perfiles, recibos, pagos, papeletas y certificados del 182 van atados al usuario de la sesión.
- **Dinero:** importes en Decimal y céntimos, calculados en el servidor; cobros y remesas serializables y condicionados al estado; la mesa idempotente frente a cortes de WiFi; el número de hermano sin duplicados.
- **Ropero:** préstamo condicionado (no hay doble préstamo) y no se presta a nadie de baja.
- **Subidas y HTML:** tipo real por contenido, fotos recodificadas a WebP sin EXIF, ClamAV que falla cerrado, sin SVG; HTML saneado en servidor y cliente, enlaces de bloques solo internos.
- **Configuración:** CORS cerrado, trust proxy coherente con los dos nginx, límites de cuerpo por ruta, limitadores en todo lo público, CSP y HSTS, contenedores sin root.
- **Web pública:** ni una «Hermandad» ni «Cofradía» en texto visible; datos de la entidad desde `datos-entidad.json`; ningún enlace interno roto; esqueleto y «Volver a intentar» si la API falla; `alt` obligatorio en el CMS.
- **Rendimiento:** todas las páginas con `lazy()`; mapa y editor fuera de la web pública; fuentes propias; listados paginados con desempate.
- **Auditoría del 11-09:** los cinco altos (2FA, contacto, siembra, ficha del hermano, anular papeleta) siguen arreglados.

Lo que tiene que decidir la Junta

- **Cierre del ejercicio:** no existe; hoy se pueden corregir o borrar apuntes de años ya presentados (cuentas, Modelo 182).
- **Baja con cosas pendientes:** qué hacer con la papeleta del año, la ropa prestada y los recibos por cobrar (también al fallecer).
- **Recibo ya en el banco:** si se puede anular, y qué se hace si el banco lo carga igualmente.
- **Cuota anual:** si va también a menores y a fichas sin cuenta propia (hoy, a todos los activos).
- **Pendientes desde el 11-09:** si los números de las bajas se reservan o se reutilizan; si inscribir con cuotas pendientes debe bloquearse; la edad de emancipación (hoy 18).
- **2FA obligatorio para los cargos:** ya en la hoja de ruta (PC A), ver AC4.

2. Lógica de negocio e integridad de datos

NG1 **Un recibo devuelto se puede cobrar dos veces** ALTA

`pagos/pago-en-linea.service.ts:97` · `procesion/zonas.service.ts:279-288`

El pago en línea acepta cualquier recibo DEVUELTO y el cobro de la mesa crea en cada llamada una reemisión nueva ya PAGADA, con su ingreso. Ninguno mira si ya hay una reemisión, a diferencia de las cuotas que cuentan y los impagos.

Escenario: el hermano empieza a pagar en línea su cuota devuelta y va al banco; mientras, la mesa le cobra en efectivo y nace «Cuota 2025 (reemisión)». Llega el aviso del banco, el total cuadra y se crea «(reemisión 2)»: paga dos veces, con dos ingresos en Contabilidad. Igual con la ficha de la mesa abierta en dos ordenadores.

Arreglo: en el pago en línea y en el cobro, rechazar con 409 el DEVUELTO que ya tenga reemisión, comprobándolo dentro de la transacción.

NG2 **Dar de baja no toca solicitudes, papeletas ni ropa** MEDIA

`censo.service.ts:349` · `mis-fichas.service.ts:193` · `mis-datos.service.ts:176`

La baja (también por fallecimiento) deja vivas sus solicitudes y papeletas, la Puerta del templo le deja entrar y la ropa sigue a su nombre.

Escenario: un hermano fallece en Cuaresma con la papeleta recogida; sigue en el reparto por antigüedad y en «faltan por entrar».

Arreglo: al dar de baja, cancelar solicitudes vivas, avisar de las papeletas del año y que la Puerta responda «de baja». Qué hacer con la papeleta lo decide la Junta.

NG3 **La ropa queda libre sin que nadie la haya devuelto** MEDIA

`procesion/ropa.ts:65-68` y `:121-124` (desde `papeletas.service.ts:291`)

Al anular una papeleta ya recogida, sus prendas pasan a DISPONIBLE; al prestar una túnica nueva, la anterior del mismo tipo también. No pasan por el lavado y salen de «Sin devolver».

Escenario: se anula la papeleta de un hermano enfermo; la túnica 12 sigue en su casa pero figura disponible y se le da a otro.

Arreglo: dejar las prendas PRESTADAS hasta que se devuelvan, o preguntar al anular si las ha traído y aplicar entonces el estado de devolución.

NG4 **Ingresos de tienda, apadrinamientos y donativos borrables a mano** MEDIA

`transaccion.service.ts:251-258` · `tienda.service.ts:177` · `apadrinamientos.service.ts:90` · `pagos/donativo.service.ts:160`

Esos apuntes se crean sin enlace a su origen, así que Contabilidad los trata como manuales y deja corregirlos o borrarlos.

Escenario: se borra «Tienda: pedido n.º 14»; el pedido sigue PAGADO y el Modelo 182 sigue certificando un donativo cuyo ingreso ya no existe.

Arreglo: guardar `transaccionId` en pedido, apadrinamiento y pago en línea (como en la caja) y protegerlos en los apuntes manuales.

NG5 Los cobros de una remesa llevan la fecha del clic BAJA-MEDIA

`remesa.service.ts:224` → `recibo.service.ts:307, 333`

Al dar una remesa por cobrada, cada asiento lleva la fecha de la confirmación y no la del cargo (tampoco la fecha valor de la Norma 43).

Escenario: una remesa cargada el 30-12 y confirmada el 3-1 cuenta en el ejercicio siguiente.

Arreglo: pasar la fecha del cargo al marcar como pagado.

NG6 Un recibo remesado se puede anular o cobrar en efectivo BAJA

`domain/recibo-estados.ts` · `zonas.service.ts:291` · `recibo.service.ts:298`

La web impone domiciliación para un REMESADO, pero el servidor acepta cualquier método y permite anularlo.

Escenario: el banco carga un recibo ya anulado o ya cobrado en mano: entra dinero sin recibo o el hermano paga dos veces.

Arreglo: rechazar en el servidor cualquier método distinto de domiciliación para un REMESADO; la anulación, que la decida la Junta.

NG7 Cancelar asistencia mientras se cobra BAJA

`procesion/mi-procesion.service.ts:257-273`

Comprueba si está pagado fuera de la transacción. Si la mesa o el banco cobran a la vez, la solicitud queda CANCELADA con su recibo PAGADO, sin reverso.

Arreglo: releer solicitud y recibo dentro de una transacción serializable.

NG8 «Hoy» calculado con la hora del servidor BAJA

`procesion/mesa.service.ts:140-141` · `papeletas.service.ts:63-64` · `agenda.service.ts:68, 121, 226`

Usa `setHours` en la hora local; el contenedor va en UTC. Entre las 00:00 y las 02:00 de Madrid, «esperados hoy» enseña los del día anterior, y con `TZ=Europe/Madrid` la lista sale vacía.

Arreglo: usar `diaMadrid` e `instanteDeDia`, como el resto del código.

NG9 Se puede borrar una prenda prestada BAJA

`inventario.service.ts:282`

Se pierde quién la tiene. **Arreglo:** rechazarlo con 409 y ofrecer pasarla a baja.

NG10 Deshacer compra o liquidación de lotería sin condición BAJA

`loteria/loteria.service.ts:203-210` y `:276-285`

Leen fuera de la transacción y escriben sin condición; con una liquidación simultánea, el ingreso nuevo queda suelto y pasa por «manual».

Arreglo: `updateMany` condicionado al `transaccionId` leído.

NG11 **Borrar un acto de la Agenda deja la salida sin fecha** BAJA

`agenda.service.ts:324` · `procesion/salidas.service.ts:214-217`

Sin aviso, y `fijarFecha` crea el acto y enlaza la salida sin transacción.

Arreglo: impedir o avisar al borrar un acto enlazado y meter `fijarFecha` en una transacción.

3. Acceso, sesión y autorización

AC1 El registro público dice si un DNI está en el censo MEDIA

`services/registro.service.ts:49-52, 70-73, 80-88`

Responde 409 «Ya hay una ficha en el censo con el DNI …» antes de crear nada, sin dejar rastro.

Escenario: con un titular y 8 menores inventados por petición se comprueban unos 180 DNI cada 15 minutos por IP. Saber que alguien es hermano revela sus creencias (art. 9 del RGPD). Choca con la reactivación, que a propósito contesta siempre lo mismo.

Arreglo: responder siempre «recibirás un correo» y avisar del conflicto por correo o a Secretaría; nunca devolver el DNI.

AC2 La misma fuga de DNI en el área de hermanos MEDIA

`services/mis-fichas.service.ts:62-64, 128-130` → `services/hermanos/comunes.ts:229-232`

Crear o editar una ficha propia con otro DNI responde «Ese DNI ya está registrado»; solo frena el limitador global (1000 cada 15 min).

Arreglo: limitador propio para los cambios de DNI y mensaje genérico que lleve el caso a Secretaría.

AC3 La mesa de reparto es una puerta lateral al censo MEDIA

`routes/procesion.routes.ts:50, 75, 79, 94` · `services/procesion/mesa.service.ts:102-125, 157-163, 387-393`

El censo está limitado a Admin, Secretaría y Hermano Mayor, pero la mesa admite también Tesorería y Albacería, todo el año. Pueden buscar por DNI, teléfono o email; ver DNI, contacto y nacimiento de cualquier ficha (bajas, pendientes y difuntos incluidos), y corregirlos.

Escenario: una cuenta de Albacería recorre los id y se lleva los contactos de todo el censo.

Arreglo: solo fichas activas, rutas abiertas solo con el plazo de papeletas, o sin DNI ni contacto para los roles que no son de censo.

AC4 El 2FA sigue siendo voluntario para los cargos MEDIA

`middleware/checkRole.ts` · `services/auth.service.ts:212` — ya en la hoja de ruta (PC A)

Un cargo sin 2FA entra al CMS solo con la contraseña, que además es la misma del área de hermanos.

Arreglo: exigirlo en el backend: `checkRole` rechaza las rutas de staff, salvo activar el 2FA, si no está activado. Redirigir en la web no basta.

AC5 El bloqueo del segundo factor no va a más BAJA

`services/auth/codigos-2fa.ts:45-58` · `utils/contador-fallos.ts`

5 fallos y 15 minutos, siempre igual y sin aviso. Con la contraseña se prueban unos 480 códigos al día (cerca de un 40 % de acierto en un año), y se puede dejar al cargo fuera del CMS indefinidamente.

Arreglo: bloqueo creciente (15 min, 1 h, 4 h…) y correo al titular al bloquearse.

AC6 Documentos privados del alta al alcance de todo el CMS

MEDIA

`routes/subida.routes.ts:18, 26-31` — también DS4

La descarga de `storage/private` (certificados de bautismo, fotos de las altas) acepta los seis roles de staff, Redes incluido, cuando solo los trata el censo.

Arreglo: limitarla a los roles del censo.

AC7 Altas directas desde la mesa sin Secretaría

BAJA · POR CONFIRMAR

`routes/procesion.routes.ts:78` · `services/procesion/mesa.service.ts:327-360`

Tesorería y Albacería pueden dar de alta hermanos activos con número y colgar un menor de la cuenta de cualquier hermano; en cambio, activar se reserva a Admin y Secretaría.

Arreglo: alinear los roles; si se mantiene, que el tutor confirme o pase por Secretaría.

AC8 No hay «cambiar contraseña» con la sesión abierta

INFO

Solo la recuperación por correo. No es una brecha, pero un cargo que sospecha depende del correo.

AC9 CORS sin PATCH

INFO · POR CONFIRMAR

`app.ts:87`

Solo afectaría si web y API fueran por orígenes distintos; tras nginx van por el mismo.

4. Subidas, datos personales y configuración

DS1 La foto del alta nunca se borra — MEDIA

`utils/documentos-privados.ts:6`

El patrón de nombres admite `jpg|jpeg|png|pdf|doc|docx` pero no `webp`, y la foto del alta se recodifica a `.webp`. Al rechazar una solicitud, suprimir una cuenta por RGPD o borrar una ficha, el certificado se borra y la foto (a veces de un menor) se queda para siempre. La limpieza de huérfanos tampoco mira esa carpeta.

Arreglo: añadir `webp`, una prueba que lo compruebe y un barrido de los huérfanos que ya haya.

DS2 Producción arranca con el pago de pruebas — MEDIA

`config/entorno.ts:148` · `domain/redsys.ts:42`

Con `PAGO_EN_LINEA=simulado` o sin `REDSYS_ENTORNO=real`, solo se registra un aviso. En modo pruebas se firma con la clave pública de pruebas de Redsys, escrita en el código.

Escenario: producción sale copiando la configuración de pruebas; cualquiera firma una notificación con «pago aceptado» para su pedido y papeletas, tienda, apadrinamientos y donativos quedan pagados y asentados sin cobrar nada.

Arreglo: en producción, error al arrancar salvo un permiso explícito que solo tenga el servidor de pruebas.

DS3 El CSV del censo no neutraliza fórmulas — BAJA-MEDIA

`domain/censo-hoja.ts:273-279`

Una dirección del alta pública que empiece por `=` se convierte en fórmula al abrir el CSV en Excel (el .xlsx no está afectado).

Arreglo: anteponer `'` a toda celda que empiece por `= + - @`, tabulador o retorno.

DS5 Datos personales en los registros de correos fallidos — BAJA

`services/correos/envio.ts:149, 154-158`

El error se vuelca entero, con la dirección del destinatario, y la auditoría guarda el asunto (a veces con el nombre) durante 730 días, fuera del alcance de la supresión RGPD.

Arreglo: registrar solo el código del error y guardar la clave del uso de correo en lugar del asunto.

DS6 Albacería y Tesorería no pueden subir fotos — BAJA · FUNCIONAL

`routes/subida.routes.ts:34`

Gestionan inventario, tienda y apadrinamientos, pero la subida pública les da 403.

Arreglo: añadir esos roles o un permiso de subida por sección.

DS7 Textos sin longitud máxima BAJA

`config/common.ts:9`

`textoRequerido` no tiene tope; un valor más largo que la columna da un 500 sin traducir.

Arreglo: tope de longitud acorde a la columna.

DS8 Notificación de Redsys mal formada da 500 INFO

`domain/redsys.ts:190`

Decodifica antes de comprobar la firma; un `%` mal formado ensucia los registros. **Arreglo:** `try` que devuelva 400.

DS9 Imágenes de Docker sin fijar INFO

`docker/web.Dockerfile` · `compose.yaml`

`nginx:1.27-alpine` ya superada y `certbot:latest`. La subida escribe en `storage/public` antes de validar (inexplotable por el nombre aleatorio). **Arreglo:** fijar versiones y validar en una carpeta temporal.

DS10 Importar el censo sin tope tras descomprimir INFO

`services/censo-hoja.service.ts:61`

Un .xlsx pequeño muy comprimido puede llenar la memoria; solo lo suben cargos del censo. **Arreglo:** comprobar el tamaño descomprimido antes de cargarlo.

5. Web pública, contenido, SEO y accesibilidad

WP1 **El rojo de los errores casi no se lee** MEDIA

`theme/index.ts:48, 116-119` · `components/bloques/BloqueContacto.tsx:125-160`

El rojo de serie da 2,9:1 sobre el fondo oscuro (AA pide 4,5:1). Hazte hermano ya lo corrige; contacto, Apadrina, cesta de la tienda y donativo no.

Arreglo: `error.main: '#f08a84'` en el tema público.

WP2 **Descripciones duplicadas en cada página** MEDIA

`index.plantilla.html:22, 41-46` · `components/MetaDePagina.tsx` · `routes/index.tsx:136-140`

Con React 19 las meta de cada página se añaden al final y las estáticas no se quitan: dos `description` (la general primero) y Open Graph repetido. Google puede quedarse con la general.

Arreglo: al arrancar, borrar las meta estáticas que va a poner React y quitar las repetidas del marco.

WP3 **Una noticia inexistente no da «no encontrada»** MEDIA

`features/actualidad/noticias/NoticiaDetallePage.tsx:39-60`

El 404 de la API acaba en «No se ha podido cargar la noticia… Volver a intentar», sin `noindex`.

Arreglo: con un 404, pintar la página de no encontrada.

WP4 **Sin salto al contenido ni foco al navegar** MEDIA

`app/MarcoPublico.tsx` · `components/TransicionDePagina.tsx`

Con teclado hay que recorrer el menú en cada página y el lector de pantalla no anuncia el cambio.

Arreglo: enlace oculto «Saltar al contenido» y llevar el foco al `h1` al cambiar de ruta.

ID	GRAVEDAD	QUÉ PASA	DÓNDE Y ARREGLO
WP5	baja	El justificante de pedido y el de apadrinamiento muestran nombre y compra y son indexables.	`PedidoTiendaPage.tsx:50`, `GraciasApadrinamientoPage.tsx:40`. `noindex` y `Disallow` en robots.txt.
WP6	baja	Los desplegables del menú no se abren con Enter ni Espacio y no tienen foco visible.	`MenuEscritorio.tsx:63-83`. `onClick` que alterne y contorno dorado en `focus-visible`.
WP7	baja	El foco del enlace activo del menú es casi invisible.	`MenuEscritorio.tsx:28`. Contorno dorado de 2 px.
WP8	baja	Diez espacios pasan como mensaje de contacto válido.	`contacto/schema.ts:27` y su esquema del backend. Recortar antes del mínimo.
WP9	baja	El formulario de contacto no lleva `autoComplete` (WCAG 1.3.5).	`BloqueContacto.tsx:125-160`. `name`, `email`, `tel`.
WP10	baja	La entrada escalonada de la tienda ignora «reducir movimiento».	`TiendaPage.tsx:40-46`. `animation: none` en la media query.

WP11	baja	Un mensaje visible dice «cofrade» en vez de «hermano».	`mi-procesion.service.ts:80`.
WP12	info	Comentario del JSON-LD desfasado y dirección de la sede escrita tres veces.	`index.plantilla.html:62-64`, `config/site.ts`. Una sola fuente.
WP13	info	El sitemap no lista noticias y sí módulos apagados.	`scripts/generar-sitemap.mjs`. Servirlo desde la API.
WP14	info	La imagen para redes es `.webp`; algunas vistas previas no la muestran.	`index.plantilla.html:46`. Usar `hero.jpg`.

6. Frontend y rendimiento

FR1 Se pierde lo escrito al caducar la sesión del CMS

ALTA

`lib/api/cliente.ts:171` · `routes/ExigeRol.tsx:21` · `backend/src/utils/jwt.handle.ts:67`

La sesión dura 8 h fijas y la actividad no la renueva. Al guardar llega un 401, la web redirige al acceso y desmonta el formulario; el aviso de cambios sin guardar se desmonta con él. Tampoco hay aviso al recargar o cerrar la pestaña. Si la comprobación de sesión falla un momento, echa también a la sesión buena.

Escenario: quien entró a las 9:00 guarda una noticia larga a las 17:05 y pierde el texto.

Arreglo: ante un 401 en una ficha, guardar el borrador, pedir el acceso en una ventana sin desmontar el formulario y avisar al salir con cambios.

FR2 Cerrar sesión no limpia la caché

MEDIA · PRIVACIDAD

`features/altas/auth/session.ts:58-65` · `areaHermano/recibos/CertificadosDonativos.tsx:15`

Las consultas no llevan el usuario en la clave y no se vuelven a pedir en 5 minutos.

Escenario: en el ordenador de Secretaría, el hermano B entra al poco de salir A y ve los certificados de donativos de A con NIF e importes. Igual entre cargos en el CMS.

Arreglo: `queryClient.clear()` al cerrar sesión y al cambiar de usuario.

FR3 La web pública descarga código del CMS

MEDIA

`vite.config.ts:31-50` · `routes/index.tsx:1-12`

La portada baja 382 KB gzip de JS (1,23 MB sin comprimir) y una página por bloques, 438 KB. Tres causas: React acaba en el trozo de formularios y arrastra zod y react-hook-form a todas las páginas; el trozo de MUI mete los 165 iconos y componentes que solo usa el CMS; los marcos del CMS y del área de hermanos van en el trozo de entrada. Probado: reorganizando los trozos la portada baja a 348 KB.

Arreglo: `lazy()` para los marcos, iconos fuera del trozo de MUI y quitar el grupo de formularios.

FR4 Todos los bloques en un solo trozo

MEDIA

`components/bloques/borrador.ts` (42 KB gzip)

Cualquier página descarga todos los renderizadores (calendario, cronología, carrusel, donativo, contacto…) aunque use dos.

Arreglo: registro de bloques con `lazy()` por tipo, al menos los pesados.

FR5 Fotos del héroe a 1920 px y todas a la vez

MEDIA

`features/inicio/Hero.tsx:180-187` · `controllers/subida.controller.ts:82-87`

Cada subida se guarda en una sola variante y el héroe monta todas las fotos de la rotación. Un móvil de 390 px baja varias fotos de 200-400 KB, y la primera espera a JS y a la API.

Arreglo: variantes de 640/1280/1920 con `srcset`, y montar solo la foto activa y la siguiente.

FR6 Guardar una página relee la base por cada foto MEDIA

`utils/ficheros-publicos.ts:80-110` (desde `contenido.service.ts:105`)

Por cada foto candidata a borrar lee todas las páginas y sus versiones (unas 1.000 filas con su JSON) y busca en 7 tablas.

Arreglo: leer el contenido una vez por guardado.

ID	GRAVEDAD	QUÉ PASA	DÓNDE Y ARREGLO
FR7	baja	Un `localStorage` sin proteger tumba la web si el almacenamiento está bloqueado.	`features/altas/auth/session.ts:42`. Envolver en `try/catch`.
FR8	baja	`Transaccion` no tiene índices y todo filtra por fecha.	`schema.prisma:434-460`. `@@index([fecha])` y `@@index([categoriaId, fecha])`.
FR9	baja	Al volver de una noticia, el archivo se recarga desde la página 1.	`BloqueListado.tsx:184-199, 335-379`. `useInfiniteQuery`.
FR10	baja	47 pantallas cargan con `useState` + `useEffect` en vez de React Query; publicar una noticia no refresca la portada hasta 60 s después, y una respuesta tardía puede pisar la ficha nueva.	`NoticiasAdminPage.tsx:42-60`, `useFichaCms.ts:54-70`. Migrar poco a poco a `useQuery`.
FR11	baja	La barra se repinta unas 80 veces seguidas al desplazarse cerca de arriba.	`BarraDeNavegacion.tsx:34-62`. Oyente pasivo y variable CSS.
FR12	baja	Las lecturas públicas y `/images/` salen sin caché; cada visita son unas 8 peticiones a la base.	Controladores públicos y `docker/nginx/sitio-local.conf:71`. `max-age=60` o microcaché de nginx.
FR13	info	Los marcos del CMS y del área de hermanos duplican cajón, barra y menú.	Aceptable por los temas distintos; partirlos junto con FR3.

7. Tipos, pruebas y salud del proyecto

ID	GRAVEDAD	QUÉ PASA	DÓNDE Y ARREGLO
SA1	media	La prueba de la siembra lee la fila viva de la base local, que tiene el recorrido editado (9 paradas en vez de 19): falla siempre en este PC.	`test/contenido-api.test.ts:64-65`. Comparar con `contenido-por-defecto.json`.
SA2	media	La guarda del CI solo reconoce un texto de omisión; unas 30 pruebas de seis ficheros más se omitirían sin base y el CI seguiría en verde.	`.github/workflows/verificacion.yml:136`. Unificar el motivo con «requiere MariaDB».
SA3	baja	El CI comprueba los tipos de la web con `tsc --noEmit` y deja fuera la config de Vite y los scripts.	`verificacion.yml:164`. Usar `npx tsc -b`.

SA4	baja	Dos pruebas del ropero se omiten si falla la anterior: un fallo en cadena sale como omitido.	`test/inventario-ropero.test.ts:162, 172`. Que cada una cree su prenda.
SA5	baja	Sin prueba HTTP: cíngulos y lavadas del ropero, retablo, secciones, páginas, avisos de la mesa y `una-vez`. Los PDF solo comprueban el estado 200.	Una prueba HTTP para cíngulos y lavadas y otra para el retablo con permisos.
SA6	baja	Revisadas las aserciones negativas de la web: no se vio ninguna que pase sin mirar.	Nada urgente.
SA7	baja	Código muerto en la web.	`GaleriaDeFotos.tsx`, `PanelHermanoPage.tsx`, `theme/tarjeta.ts`. Borrarlos.
SA8	baja	Código muerto en el backend.	`dtos/admin.dto.ts`. Borrarlo.
SA9	baja	Comentario que dice qué y no por qué.	`procesion.routes.ts:14`. Quitarlo.
SA10	baja	34 avisos de lint: refs leídas en el render, un efecto sin una dependencia y 10 `setState` en efectos.	`InformeAnualPage.tsx:142, 168, 180`, `RoperoPorGrupos.tsx:115` y otros ocho.
SA11	info	Los 14 JSON de `shared/` se usan igual en los dos lados.	Sin divergencias.
SA12	info	Restos fuera de git: `.superpowers/` (45 MB), `.tmp/`, `.playwright-mcp/`, `test-output.log`, `dist/`.	Limpiarlos a mano si se quiere.